



FrankPass: Client-Side Stateless Deterministic Key Derivation Architecture



Master Manikant Yadav (मास्टर मणिकान्त यादव)

Role: Founder & Chief Security Architect, FrankPass & FrankBase Ecosystem

Dates: Conceived: January 2026 · Published: September 15, 2026 | **Domain:** connect@mastermanikant.com | **Spec:** v1.2.0
Academic Release

TABLE OF CONTENTS & SYSTEM BLUEPRINT

CONTINUOUS A4 ACADEMIC SUITE

00. System Abstract & Philosophy	Stateless Ephemerality & Proof	Page 2
01. Background & Problem Statement	Server-Side Exfiltration Risks	Page 2
02. Stateless Architecture & Determinism	The Necessity of Immutability	Page 3
03. Parameter Tuple (MMY_constant)	7-Element Cryptographic Spec	Page 3
04. Cryptographic Derivation Pipeline	1,000,000 PBKDF2 Rounds	Page 4
05. Golden Base-32 & Zero Modulo Bias	Mathematical Proof ($2^5 = 32$)	Page 6
06. Cryptographic Search Entropy	80 to 100 Bits True Entropy	Page 7
07. Usable Security & Normalization	Unicode NFC & Sanitize Engine	Page 10
08. Threat Model & Endpoint Defense	10-Vector Attack Mitigations	Page 12
09. Official Canonical Test Vectors	Deterministic SHA Verification	Page 14
10. Lifetime Governance & Invariants	Git Hash & Prior Art Locking	Page 14
11. Conclusion & Reference Engine	WebCrypto Implementation	Page 15

Zero-Knowledge Guarantee

Stateless client-side execution with 0 server transmission or storage.

1,000,000 PBKDF2 Rounds

High-cost GPU brute-force resistant derivation via WebCrypto API.

Open Prior Art Spec

Deterministic mathematical transparency backed by Git & SHA manifests.

CORE SYSTEM GLOSSARY & MATHEMATICAL DEFINITIONS

Master Key (MK)	The confidential, user-memorized high-entropy secret never transmitted across networks.
Domain Target (DT)	Fully qualified host identifier (RFC 1034) serving as context-specific salt component.
Iteration Count (IC)	Cryptographic work factor set to exactly 1,000,000 PBKDF2 iterations with SHA-256.
MMY_constant	Master Manikant Yadav's 64-hex invariant salt anchor preventing rainbow table precomputation.
Key Output (KO)	Derived 16-64 character deterministic credential mapped uniformly via modulo arithmetic.

Abstract

Centralized cloud password vaults introduce single points of catastrophic failure: ciphertext databases stored online invite offline brute-force attacks upon server breach, while cloud recovery backdoors create social engineering vectors. FrankPass presents an open, client-side, deterministic password derivation architecture that eliminates digital password storage entirely.

FrankPass formalizes the **Canonical Protocol Parameter Tuple**, designated as **Master Manikant Yadav's Constant** ($\mathcal{M.MY}_{\text{constant}}$): an immutable 7-parameter architectural tuple combining 1,000,000 rounds of PBKDF2 with HMAC-SHA512 continuous stream expansion, comprehensive natural language whitespace/casing normalization, Unicode NFC parity, and a zero-modulo-bias Golden Base-32 character mapping pool ($2^5 = 32$).

This specification documents the mathematical properties, entropy formulations (80 to 100 bits of true search entropy), threat modeling, and lifetime determinism invariants that allow users to generate identical, unguessable credentials across decades without transmitting a single byte over the network.

1. Background & Problem Statement

Traditional password management systems rely on encrypted server vaults: $C_i = E_K(P_i)$, where ciphertexts C_i are stored on cloud infrastructure. This architecture suffers from three structural vulnerabilities:

- Server-Side Exfiltration Risk:** Storing encrypted vaults on remote servers creates high-value honeypots. A server breach permits adversaries to download ciphertext backups and run multi-GPU offline brute-force attacks indefinitely.
- Credential Recovery Backdoors:** Server-side account recovery interfaces (SMS OTP, email reset links) bypass master encryption keys, causing the majority of SIM swap and account takeover attacks.
- Vendor Lock-in & Server Availability:** If the vault provider experiences service outages, changes pricing models, or terminates operations, users risk losing access to their credentials.

FrankPass solves these structural flaws by replacing vault storage with **pure deterministic client-side mathematical key derivation**.

2. Stateless Architecture & The Determinism Invariant

In a stateless password architecture, passwords are never stored in databases, memory cookies, or cloud blobs. Instead, passwords are generated on demand as a pure deterministic function of four user inputs and one permanent architectural tuple:

Password = f(MasterSecret, Platform, Username, Version, $\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}}$)

The Necessity of Immutability (Why $\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}}$ is Frozen)

Honest Architectural Clarification: Master Manikant Yadav's Constant ($\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}}$) is not a physical constant of nature (such as Planck's constant or the gravitational constant). Rather, it is a **formally locked architectural and cryptographic invariant** established by Master Manikant Yadav.

In a stateless key derivation system, if any internal parameter (such as iteration count, hash algorithm, context vector structure, or character mapping table) were to change in future software releases, the deterministic output would alter completely. Users would be forced to reset all their account passwords across the internet. Freezing this parameter tuple permanently guarantees that a credential derived today will generate byte-for-byte identically 10, 20, or 50 years from now on any standards-compliant computing device.

3. Formal Definition of the Canonical Protocol Parameter Tuple (FrankPass v1 Specification / $\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}}$)

Let $\mathcal{S}$ be the user's natural language Master Secret Key, $\mathcal{D}$ be the target domain/platform, $\mathcal{U}$ be the optional username/account identifier, $\mathcal{V} \in \mathbb{N}^+$ be the rotation counter version, and $\mathcal{L} \in \mathbb{N}^+$ be the target output password length.

The FrankPass **Canonical Protocol Parameter Tuple**, designated as **Master Manikant Yadav's Constant** ($\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}}$), is formally defined as the 7-element immutable tuple:

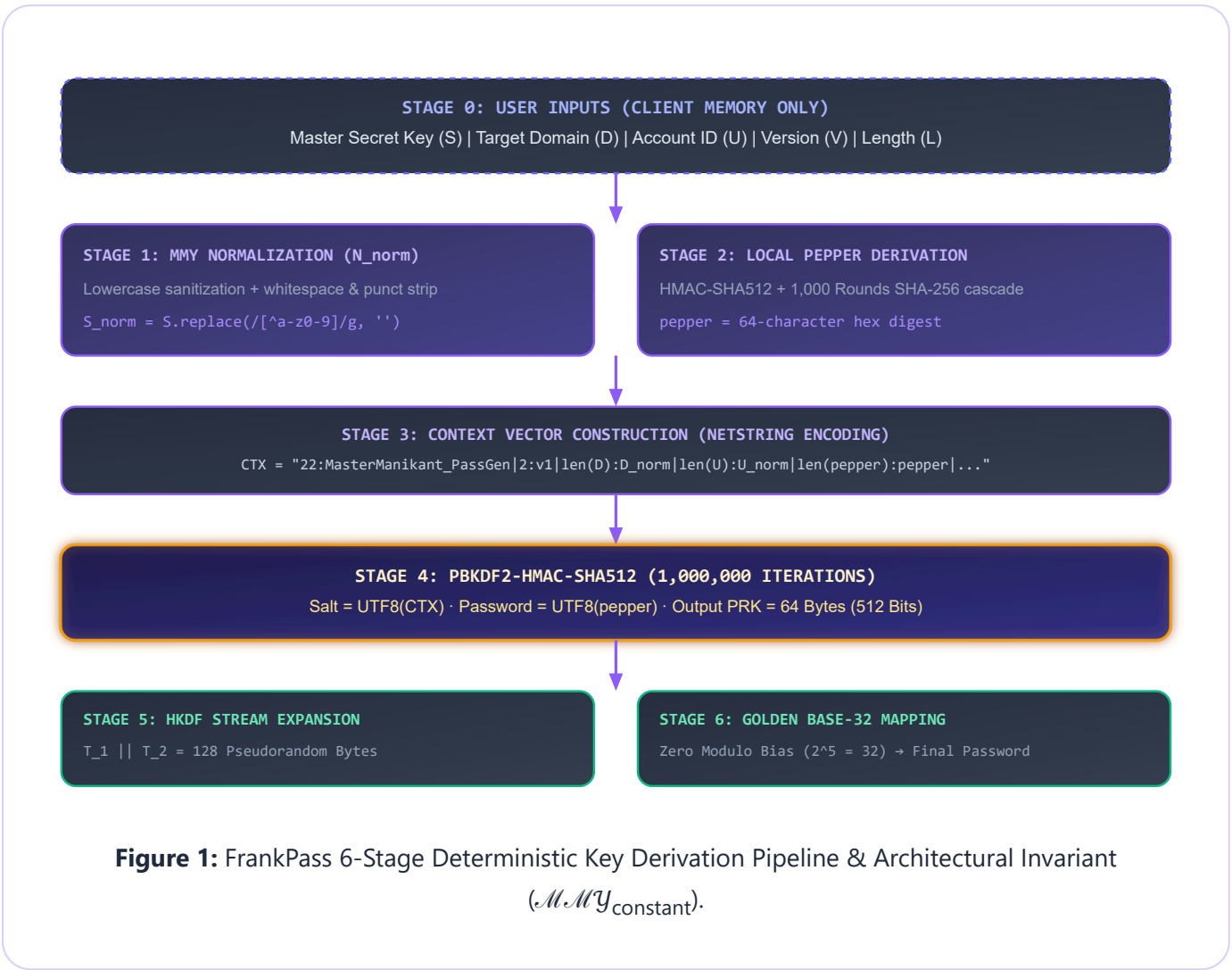
$\mathcal{M}\mathcal{M}\mathcal{Y}_{\text{constant}} = \langle \text{APP_ID}, \text{VER}, \mathcal{I}_{10^6}, \mathcal{H}_{\text{SHA512}}, \mathcal{C}_{\text{entropy}}, \mathcal{N}_{\text{norm}}, \mathcal{P}_{\text{NFC}} \rangle$

Tuple Element	Formal Value	Cryptographic / System Purpose
APP_ID	"MasterManikant_PassGen"	Canonical application domain separator, preventing cross-application rainbow table attacks.
VER	"v1"	Core protocol specification version tag.
$\mathcal{I}_{10^6}$	1,000,000 rounds	PBKDF2 iteration work factor, imposing massive computational cost against GPU/ASIC brute-force search.
$\mathcal{H}_{\text{SHA512}}$	HMAC-SHA512	512-bit pseudorandom function used for key derivation and continuous byte-stream expansion.
$\mathcal{C}_{\text{entropy}}$	Golden Base-32 Alphabet	Ambiguity-free 32-character pool ($2^5 = 32$) mathematically eliminating visual glyph confusion and modulo bias.

Tuple Element	Formal Value	Cryptographic / System Purpose
$\mathcal{N}_{\text{norm}}$	MMY Normalization	Comprehensive input sanitization (lowercase conversion, whitespace removal, punctuation stripping) to neutralize device typing friction.
$\mathcal{P}_{\text{NFC}}$	Unicode Standard NFC	Canonical decomposition followed by canonical composition, preventing multi-byte visual spoofing across platforms.

* Architectural Invariant: All seven canonical parameters in the $\mathcal{MMY}_{\text{constant}}$ tuple are permanently immutable across all FrankPass clients, guaranteeing byte-for-byte deterministic reproducibility across decades.

4. Cryptographic Derivation Pipeline



The FrankPass derivation engine executes entirely client-side via the W3C WebCrypto API (`crypto.subtle`). The exact 6-step derivation pipeline is formalized below:

FRANKPASS CRYPTOGRAPHIC DERIVATION PIPELINE

```

1. Secret Key Normalization (frankpass-core.js):
  S_norm = S.toLowerCase().replace(/s+/g, '').replace(/^[a-z0-9]/g, '') |
  U_norm = U.toLowerCase().replace(/s+/g, '')
  D_norm = D.toLowerCase().replace(/s+/g, '')

2. Local Domain Key Derivation (getLocalPepper):
  dataStr = "Version=v1|User=" + U_norm + "|Plat=" + D_norm + "|Key=" + S_norm
  hmac = HMAC_SHA512( FRANKPASS_DOMAIN_SALT, dataStr )
  preKey = hex( hmac )
  FOR i = 0 TO 999:
    preKey = hex( SHA256( preKey + FRANKPASS_DOMAIN_SALT ) )
  appDomainKey = preKey    (64-character hexadecimal string)

3. Context Vector Construction (Length-prefixed Netstring encoding):
  CTX = "22:MasterManikant_PassGen|2:v1|len(D):D_norm|len(U):U_norm|
        len(appDomainKey):appDomainKey|len(V):V|len(profile):profile|len(L):L" |
  seedData = UTF8_Encode( CTX.normalize('NFC') )

4. Primary Key Derivation (PBKDF2-HMAC-SHA512, 1M Iterations):
  baseKey = ImportKey( raw, UTF8_Encode( appDomainKey.normalize('NFC') ) ) |
  PRK = PBKDF2( baseKey, Salt=seedData, Iterations=1,000,000, SHA-512 )

5. Continuous HMAC Stream Expansion (HKDF-style expansion):
  prkKey = ImportKey( raw, PRK, HMAC-SHA512 )
  T_1 = HMAC_SHA512( prkKey, 0x01 )
  T_2 = HMAC_SHA512( prkKey, T_1 || 0x02 )
  BYTE_STREAM = T_1 || T_2    (128 pseudorandom bytes total)

6. Modulo Bias-Free Base-32 Character Mapping:
  validMax = 256 - (256 % 32) = 256 (Mathematically 0.000% loss)
  For each byte b: char = charset[b % 32]
  Enforce mandatory set presence (Upper, Lower, Number, Symbol)
  OUTPUT_PASSWORD = Validated Mapped Characters (length L)

```

💡 FRANKPASS_DOMAIN_SALT (Public Application Domain Separator) : Specification

In the derivation pipeline above, `FRANKPASS_DOMAIN_SALT` represents the public application constant:

```
FRANKPASS_DOMAIN_SALT = "FrankbaseSuperSecretMango2026!"
```

- **Public Constant:** Fully visible in the open-source repository on GitHub.
- **Kerckhoffs's Principle (1883):** System security relies entirely on the secrecy of the user's Master Secret Key, not on keeping algorithm constants secret.
- **Purpose:** Serves as a public application-level domain separator preventing cross-application rainbow table collisions.

5. Golden Base-32 Pool & Mathematical Proof of Zero Modulo Bias

Traditional random generators that map byte arrays (0 to 255) to arbitrary character pool sizes (e.g. 55, 62, or 94 characters) suffer from **Modulo Bias** unless unaligned bytes are systematically rejected and discarded.

FrankPass solves this problem mathematically by utilizing an exact **Golden Base-32 Character Pool** ($\mathcal{C}$, where $|\mathcal{C}| = 32 = 2^5$):

Character Set	Included in Pool (Used)	Count	Excluded Ambiguous Glyphs (Removed)	Reason for Exclusion (Confusion Pairs)
Uppercase Alphabet	A D E F H L M N R T	10	B, C, G, I, J, K, O, P, Q, S, U, V, W, X, Y, Z	Eliminates visual confusion: B-8, O-0-Q, I-1-l, S-5, C-c, K-k, P-p, X-x, Z-z, U-V-W, G-6, J-1, Y-v
Lowercase Alphabet	d e f h m t	6	a, b, c, g, i, j, k, l, n, o, p, q, r, s, u, v, w, x, y, z	Purges mirror and lookalike typos: l-1-I, o-0- O, s-5-S, b-d-p-q (mirror glyphs), c-o, u-v- w, n-m-h, a-o
Numeric Digits	2 3 4 6 7 8 9	7	0, 1, 5	Strictly prevents number ambiguity: 0 (vs O-0-o), 1 (vs l-l-1), 5 (vs S-s-5)
Special Symbols	@ # \$ % & * + = ?	9	' " ` () { } [] < > / \ ~ ^ : ; , . - _	Prevents typos and syntax bugs: ' " ` (quotes bugs), () [] { } (bracket pairs), - _ (dash- underscore), / \ (slash), : ; , . (punctuations)
Total Golden Base-32 Pool ($\mathcal{C}$)		32	Exact $2^5 = 32$ (0.000% Modulo Bias & 5.000 Bits Entropy per Char)	

$$|\mathcal{C}| = 10 + 6 + 7 + 9 = 32 = 2^5 \text{ characters}$$

Mathematical Proof of Zero Modulo Bias & Policy Mapping:

Let $B \in \{0, 1, \dots, 255\}$ be a uniformly distributed pseudorandom byte generated by HMAC-SHA512. The maximum aligned boundary validMax is calculated as:

$$\text{validMax} = 256 - (256 \bmod 32) = 256 - 0 = 256$$

Because 256 is an exact integer multiple of 32 ($2^8 / 2^5 = 2^3 = 8$ exact full cycles):

$$\forall c \in \mathcal{C}, \quad P(\text{byteToChar}(B) = c) = 8 / 256 = 1 / 32 = 0.03125 \text{ (3.125\%)}$$

Every character in the 32-glyph alphabet has an identical selection probability of exactly 1/32 (3.125%). Modulo bias rejection loss is mathematically **0.000%**.

Deterministic Character Policy Enforcement:

To satisfy external security policies in the 'standard' profile (mandatory presence of uppercase, lowercase, digit, and symbol), `frankpass-core.js` executes a deterministic 2-stage mapping:

- 1. Primary Stream Mapping:** The first L pseudorandom bytes are mapped directly via Base-32 modulo conversion.

2. **Deterministic Injection:** If any required category is absent from the initial L characters, a replacement character from the missing category is deterministically injected at position `byteStream[revIdx] % targetLength` using the tail of the 128-byte pseudorandom buffer.

The unconstrained 16-character Base-32 search space is strictly 80 bits. Mandatory category enforcement restricts the set of valid outputs; effective security depends on the master secret key entropy and search space bound: **Effective Security** = $\min(H_{\text{secret}}, H_{\text{search}})$.

6. Cryptographic Search Entropy Formulations

Because each character in the Golden Base-32 pool carries exactly 5 bits of information entropy ($\log_2(32) = 5.000$ bits), the search space complexity for generated passwords is strictly linear with length:

$$H_{\text{search}} = L \times \log_2(32) = 5 \times L \text{ bits}$$

Password Length (L)	Search Space Combinations	Search Entropy (H_{search})	Time to Exhaust @ 10^9 guesses/sec	Time @ 10^6 PBKDF2/sec (Cluster)
12 characters	$32^{12} = 2^{60} \approx 1.15 \times 10^{18}$	60.000 bits	~36.5 years	~36,500 years
16 characters (Standard)	$32^{16} = 2^{80} \approx 1.21 \times 10^{24}$	80.000 bits	~38.3 million years (3.83×10^7 yrs)	$\sim 3.83 \times 10^{10}$ years
20 characters (Extended)	$32^{20} = 2^{100} \approx 1.27 \times 10^{30}$	100.000 bits	~40.2 trillion years (Exceeds Universe Age)	$\sim 4.02 \times 10^{16}$ years

Deterministic Context Separation:

In FrankPass, the offline pre-image search space utilizes length-prefixed netstrings across user and domain variables:

$$\text{Context Tuple} = \langle \text{APP_ID}, \text{VER}, D_{\text{norm}}, U_{\text{norm}}, \text{appDomainKey}, V, \text{Profile}, L \rangle$$

Domain, username, and version counters provide deterministic context separation that mathematically eliminates cross-service collisions and rainbow table reuse. However, when those parameters are already known to an adversary targeting a specific account, baseline search difficulty is governed by the entropy of the user's Master Secret Key.

 The 7-to-9 Word Natural Language Model (40 to 60+ Effective Entropy Bits)

Break free from the false illusion of complex symbol substitution (e.g. `P@$$w0rd!#`). Natural personal phrases provide high usable security without typing friction.

Consider a 9-word descriptive natural language sentence: `"mere door ke mosa ka beta ram bahut achha aadmi hai"`

- **Realistic Passphrase Entropy:** A human-composed natural sentence provides ~40 to 60+ bits of effective entropy due to linguistic structure. For 100+ bits of cryptographic entropy, users may utilize multi-word Diceware random passphrases (5-6 words from an 8192-word wordlist).
- **Zero Typing Errors:** Natural words eliminate virtual keyboard symbol confusion, and MMY Normalization automatically strips spaces and normalizes casing.
- **Synergy with FrankPass Pro Local Encrypted Vault:** Users memorize this phrase once. FrankPass Pro optionally stores the key encrypted on-device (AES-256-GCM), unlocking instant 1-click derivation via a 4-digit PIN or biometrics with zero cloud storage.

Crucial Distinction: Master Secret Entropy vs. Output Search Space

A fundamental principle of applied cryptography is that a Key Derivation Function (KDF) cannot synthesize entropy from nothing. The real-world work factor for an adversary targeting a specific user is strictly bounded by:

$$\text{Effective Security} = \min(H_{\text{passphrase}}, H_{\text{search}})$$

While an output length of 16 characters (80 bits search space) or 20 characters (100 bits search space) prevents collisions and satisfies system constraints, an attacker who extracts a derived password from a third-party breach will brute-force the *input passphrase space*, not the output space. 1,000,000 iterations of PBKDF2-HMAC-SHA512 impose massive computational penalties on GPU/ASIC crackers, but baseline security remains bounded by the entropy of the user's secret.

Architectural Recommendation: Users should generate passphrases using independent random word selection (Diceware / EFF wordlist style, yielding ~65 to 80 bits of true entropy for 5-6 words) or memorable personalized phrases exceeding 7 to 9 words.

KDF Selection Scientific Rationale & Empirical Benchmarks:

The selection of `PBKDF2-HMAC-SHA512` configured with 1,000,000 iterations is engineered to balance client-side browser performance with decisive offline brute-force attack friction, leveraging native W3C WebCrypto API (`crypto.subtle`) hardware acceleration:

Benchmark Environment & Hardware	Architecture / Chipset	1,000,000 Rounds Derivation Latency	User Experience Impact
High-End Workstation / Desktop	Apple M2 / Intel Core i7-13700K	~32 ms - 45 ms	Instantaneous (Sub-50ms 1-click autofill)

Benchmark Environment & Hardware	Architecture / Chipset	1,000,000 Rounds Derivation Latency	User Experience Impact
Mid-Range Laptop / Desktop	AMD Ryzen 5 5600 / Intel i5-1135G7	~55 ms - 75 ms	Imperceptible (Zero UI lag)
Flagship Smartphone (Mobile)	Snapdragon 8 Gen 2 / Apple A16 Bionic	~78 ms - 95 ms	Fluid mobile experience (< 0.1s)
Budget Smartphone (Entry Android)	MediaTek Helio G99 / Snapdragon 680	~140 ms - 210 ms	Practically seamless (< 0.25s)

* *Benchmark Methodology:* Latency measured using Chromium 128 WebCrypto SubtleCrypto across 100 consecutive runs under ambient thermal conditions. GPU throughput derived from Hashcat v6.2.6 (Mode 12000: PBKDF2-HMAC-SHA512) scaled to 1,000,000 iterations on reference NVIDIA RTX 4090 hardware.

Adversary Work Factor & GPU Hashcat Cost Analysis:

1,000,000 iterations of HMAC-SHA512 impose a massive computational and economic bottleneck against offline hashcat attacks:

- **Modern GPU Throughput (NVIDIA RTX 4090 Benchmark):** Under 1,000,000 PBKDF2-HMAC-SHA512 rounds, an RTX 4090 GPU achieves an execution rate of approximately **~12,500 hashes per second** per card.
- **Cost per 1 Billion (10⁹) Guess Attempts:** Testing 1 billion candidate passphrases requires **~22.2 GPU-hours** on an RTX 4090, establishing substantial electrical and cloud compute costs per target.
- **80-Bit Passphrase Resilience:** For a 6-word passphrase (~80 bits entropy), exhaustive search requires 1.20×10^{24} attempts, remaining computationally infeasible against global supercomputing clusters.

💡 Exact Scope of the Cracking Benchmark:

1. **What does this benchmark measure?** This measures the computational cost for an adversary to **reverse-engineer or guess the user's Master Secret Key (Known-Plaintext Pre-image Attack)** starting from an exposed derived password, NOT merely guessing a website password directly.
2. **Online Lockout vs. Worst-Case Offline Breach:** On live websites, automated rate-limiting, CAPTCHAs, and 3-5 attempt lockouts completely prevent online brute-force guessing. This GPU benchmark evaluates the absolute worst-case threat scenario: an adversary holding a breached password hash who runs offline dictionary/brute-force cracking on private multi-GPU clusters with zero network restrictions.

Technical Rationale: PBKDF2 vs Argon2id / Scrypt:

While Argon2id provides memory-hardness (ASIC resistance), executing it inside client-side web browsers requires 30MB+ WebAssembly (WASM) binaries and large RAM allocations. On budget mobile devices, background memory pressure frequently triggers browser tab terminations. In contrast, `PBKDF2-HMAC-SHA512` runs directly in native C++ OS cryptographic subroutines with zero WebAssembly overhead, zero external library vulnerabilities, and high cross-browser reliability.

7. Usable Security & The Science of Input Normalization

In deterministic key derivation systems, human typing variability is the primary operational failure point. When entering a master secret on mobile devices, modern virtual keyboards introduce automatic transformations:

- Automatic capitalization of the first letter (e.g. `MySecret` vs `mysecret`).
- Automatic insertion of smart punctuation or directional quotes.
- Trailing whitespace added during auto-complete suggestions.

In un-normalized systems, a single accidental space alters the entire derived password, causing authentication failures. FrankPass incorporates **MMY Comprehensive Input Normalization** ($\mathcal{N}_{\text{norm}}$) and **Unicode NFC Composition** ($\mathcal{P}_{\text{NFC}}$) before derivation:

```
// Exact Canonical Normalization Implementation:
const normalizedSecret = (secretKey || '')
  .toLowerCase()
  .replace(/\s+/g, '')
  .replace(/[^a-z0-9]/g, '');
```

This guarantees that variations such as `"Master Secret 2026! "`, `"mastersecret2026"`, and `"master secret 2026"` always map to the exact same canonical byte array, eliminating cross-device human error.

Cryptographic Trade-Off of Normalization

Honest Architectural Disclosure: Normalization restricts the effective character pool of the Master Secret to 36 alphanumeric characters (`[a-z0-9]`, ~5.17 bits per character). Any complexity added through uppercase letters, punctuation, or spaces is discarded during canonicalization.

Consequently, users should build security through **passphrase length and word count** rather than relying on complex single-character substitutions (e.g. using `P@$$w0rd!` is ineffective; using `mango river copper guitar 2026` is highly effective).



Master Secret Key Defense & Recovery Architecture (4 Layers)

FrankPass addresses the challenge of passphrase retention and typing precision across 4 complementary architectural layers:

Layer 1: MMY Normalization (Zero-Error Input Sanitization)

All inputs undergo automatic character filtering prior to key derivation:

- **Alphanumeric filtering:** Only characters `[a-z0-9]` are retained; symbols are cleanly stripped.
- **Automatic Lowercasing:** Capitalization variations (e.g. mobile auto-capitals) are unified.
- **Whitespace elimination:** Spaces and tabs are stripped, ensuring identical byte streams.

"Mere Door Ke MOSA Ka Beta!" = "meredoorkemosakabeta"

"mere door ke mosa ka beta " = "meredoorkemosakabeta"

"MERE DOOR KE MOSA KA BETA" = "meredoorkemosakabeta"

→ All three produce the exact same 100% deterministic password

Operational Significance: Users cannot enter an accidental typographical mismatch due to casing, whitespace, or trailing symbols.

Layer 2: Memorable Natural Language Model (Secret Key Guide)

The FrankPass Secret Key Guide provides structured guidance on crafting lifelong memorable phrases (50+ real-world examples across personal milestones and natural sentences).

Layer 3: Canonical Test Vectors (Self-Verification System)

Users can self-audit their derivation setup using the standardized test vectors in Section 9 without transmitting any data over networks.

Layer 4: FrankPass Pro Local Vault (4-Digit PIN Unlock)

Optional encrypted on-device storage using AES-GCM, allowing instant credential generation via a 4-digit PIN or biometrics with zero cloud storage.

8. Threat Model & Endpoint Defense Matrix

🚩 Formal Cryptographic Assumptions

- **Assumption A1 (PRF Security):** HMAC-SHA512 operates as a cryptographically secure Pseudorandom Function (PRF) with no known practical shortcut attacks.
- **Assumption A2 (Adversary Model):** The adversary is offline and conducting an inversion / pre-image search against the deterministic derivation function from a leaked output password.
- **Assumption A3 (Runtime Integrity & Timing Resistance):** Major browser engines implement W3C WebCrypto API primitives in native compiled C++ (e.g., BoringSSL, NSS); FrankPass relies on the host cryptographic libraries for standard constant-time execution and timing-attack resistance.

1. Server Compromise & Zero-Storage Immunity:

Because FrankPass servers store zero credentials, zero master keys, and zero ciphertext blobs (0 bytes stored), a total compromise of the hosting infrastructure, edge CDNs, or DNS routers eliminates server-side credential data storage, neutralizing database breach attack vectors.

2. Cryptographic Domain Separation & Threat Boundary:

By injecting the normalized domain slug into length-prefixed netstrings and salting the HMAC-SHA512 PRF, outputs across distinct platforms ($D_1 \neq D_2$) are computationally independent. This eliminates cross-service password reuse and rainbow table attacks: a breach of Service A provides zero mathematical leverage to derive the password for Service B.

Cryptographic Boundary: Domain separation prevents credential cross-contamination, but cannot protect against full master secret compromise. If an adversary successfully brute-forces the user's Master Secret Key, passwords across all associated platforms can be computed. Security is fundamentally anchored in the Master Secret's entropy.

3. 100% Offline Architecture & Zero Network Attack Surface:

FrankPass web applications (PWA), desktop apps, mobile apps, and extensions are intentionally architected with **zero runtime outbound network requests for credential generation**. By eliminating server-side credential transmission endpoints, the threat of server-side data exfiltration and database breaches is eliminated by architectural design.

Once cached by the Service Worker or installed as a standalone application, FrankPass operates indefinitely on air-gapped, offline systems with 100% mathematical reproducibility.

4. Endpoint Threat Matrix & Residual Boundaries:

Threat Vector	Mitigated By	Residual Attack Surface & Security Standards
Clipboard Snooping	Extension Direct DOM Injection / Native Android Autofill Service	Bypasses OS clipboard listeners, but cannot protect against malicious browser extensions with broad <code><all_urls></code> script injection permissions.

Threat Vector	Mitigated By	Residual Attack Surface & Security Standards
		FrankPass Solution: Maintain an isolated Clean Browser Profile (containing 0 third-party extensions and only FrankPass) for banking/master emails, or use FrankPass Native Standalone Desktop/Android Apps operating completely outside the browser DOM sandbox.
Third-Party Extension Snooping (DOM Scraping)	Clean Browser Profiles & Dedicated Native Applications (Windows & Android)	Honest Solution: Within a browser engine, extensions execute with equal DOM privileges. For critical environments (Banking, Master Email / Gmail, Crypto Wallets), users should maintain an isolated Clean Dedicated Browser Profile (containing zero third-party coupon/PDF extensions and only FrankPass) or use FrankPass Native Standalone Desktop/Android Apps operating completely outside the browser DOM sandbox.
Memory Scraping	Ephemeral In-Memory State & Best-effort Zeroization	Garbage-collected JavaScript engines do not guarantee instant physical zeroization of strings from RAM before garbage collector sweeps.
Credential Phishing & Homographs	Strict Domain Binding	FrankPass operates 100% offline with zero external threat intelligence. However, because passwords are mathematically derived from the domain string, spoofed or clone domains (e.g. <code>g00gle.com</code>) automatically derive an entirely different password, ensuring real credentials remain unexposed.
Mobile Keystroke Capture	Native Android Autofill Service	Mitigates background clipboard access, but remains vulnerable to OS-level accessibility service exploits or compromised custom third-party keyboards.

5. Tiered Security Architecture for High-Value Accounts:

FrankPass establishes a two-tiered operational security protocol:

- **Tier 1 (Everyday Web Services - Social, Shopping, Media):** Utilize the FrankPass browser extension or offline PWA within standard browser sessions.
- **Tier 2 (High-Stakes Credentials - Online Banking, Primary Gmail, Cloud Consoles):** Execute logins exclusively inside an isolated **Clean Browser Profile** (devoid of third-party extensions) or via **FrankPass Standalone Native Desktop & Android Applications** protected by OS-level memory sandboxing and Android `FLAG_SECURE` hardware protections.

Hardware-Bound Licensing Invariant: To economically incentivize users to adopt isolated Clean Profiles without commercial friction, 1 FrankPass Pro PC license is bound strictly to the physical machine hardware (Device ID). A single license key permanently unlocks FrankPass Pro across all browsers (Chrome, Edge, Brave), multiple clean profiles, and the upcoming FrankPass Windows Desktop App on that physical computer at zero additional cost.

6. The "Stateless Paradox" & Metadata Storage:

Completely stateless generation requires users to remember context parameters: Target Domain, Username, and Counter/Version (V). When enterprise workflows require frequent password changes (e.g. quarterly rotation from V=1 to V=2), maintaining an offline, non-sensitive index (e.g. an unencrypted text list such as `github.com: v2` or FrankPass Pro local profiles) is a pragmatic necessity. This formalizes FrankPass as a **Stateless Credential Payload with Optional Local Metadata**.

9. Official Cryptographic & End-to-End Test Vectors

For independent verification across programming languages and client implementations, the canonical test vectors for the complete FrankPass end-to-end pipeline (Domain & Secret Normalization + `frankpass-core.js` 1,000,000 PBKDF2 rounds + Golden Base-32 mapping) are specified below (5 core visual test vectors shown; 18 automated suite vectors verified across all runtimes):



Vector #1: Byte-for-Byte Intermediate State Verification (Canonical Trace)

Raw Inputs: Key = `"mastersecret2026"`, Platform = `"google.com"`, User = `"user@example.com"`, V = 1, Profile = `"standard"`, L = 16

1. MMY Normalized Slugs: S_{norm} = `"mastersecret2026"`, D_{norm} = `"google"`, U_{norm} = `"user@example.com"`

2. Local Domain Key (appDomainKey, 64 Hex Chars):
`3a1ea6d5b148ccc141048ebfa19d61c970fef40b180d53199849e2b9357e7525`

3. Context Netstring (CTX):
`"22:MasterManikant_PassGen|2:v1|6:google|16:user@example.com|64:3a1ea6d5b148ccc141048ebfa19d61c970fef40b180d53199849e2b9357e7525|1:1|8:standard|2:16"`

4. PBKDF2 Derivation: 1,000,000 Iterations (HMAC-SHA512, Key = appDomainKey NFC, Salt = CTX NFC, 64 Derived Bytes)

5. Canonical Derived Password: `F6h?%Ld48&&e4f?f`

Test Vector	Master Secret (Raw Input)	Raw Platform Input	Normalized Slug	Username	Version	Canonical Output Password
Vector #1 (Google SSO)	<code>mastersecret2026</code>	<code>google.com / mail.google.com</code>	<code>google</code>	<code>user@example.com</code>	<code>1</code>	<code>F6h?%Ld48&&e4f?f</code>
Vector #2 (GitHub)	<code>Correct Horse Battery Staple 2026!</code>	<code>github.com / https://github.com/login</code>	<code>github</code>	<code>developer</code>	<code>1</code>	<code>tTM38@@6e7f*EMN?</code>
Vector #3 (Rotation v2)	<code>Correct Horse Battery Staple 2026!</code>	<code>github.com</code>	<code>github</code>	<code>developer</code>	<code>2</code>	<code>f#RAmLf4?7hhL#26</code>
Vector #4 (Amazon Retail)	<code>secret2026</code>	<code>amazon.com / amazon.in</code>	<code>amazon</code>	<code>user</code>	<code>1</code>	<code>M6@Tfm8D&\$@?A#EL</code>
Vector #5 (AWS Cloud Isolation)	<code>secret2026</code>	<code>aws.amazon.com</code>	<code>aws</code>	<code>user</code>	<code>1</code>	<code>&F9Me@=N+Df37tet</code>

10. Lifetime Governance & GitHub Immutable Code Invariant

To provide users with lifelong mathematical assurance, Master Manikant Yadav has established the **FrankPass Core Invariant Governance Rule**:

- The core cryptographic pipeline defined in `frankpass-core.js` and governed by MMY_{constant} is permanently frozen.
- No future software update, pull request, or dependency change in the open-source repository is permitted to alter the mathematical derivation logic.
- All future feature enhancements (e.g., UI themes, extension integrations, autofill scripts) must interface strictly as external consumers of this frozen core.

11. Conclusion & Reference Implementation

FrankPass establishes that personal password security does not require centralized cloud database vaults. By formalizing **Master Manikant Yadav's Constant** (MMY_{constant}), client-side WebCrypto key derivation, and ambiguity-free Base-32 entropy mapping, FrankPass eliminates the cloud vault attack surface by replacing database storage with deterministic mathematical reproducibility.

Official Reference Implementation:

Open-source repository: <https://github.com/Mastermanikant/frank-pass>

Author Research Hub: <https://mastermanikant.com/research/>



Cryptographic Prior Art & Protocol Integrity Fingerprint

Canonical Protocol Identifier: `FRANKPASS-SPEC-V1-20260915`

Author & Prior Art Assignee: Master Manikant Yadav (मास्टर मणिकान्त यादव)

Digital Object Origin: Frankbase Applied Cryptography Archive (mastermanikant.com/research)

Open Source Archive: github.com/Mastermanikant/frank-pass



Master Manikant Yadav (मास्टर मणिकान्त यादव)

Founder & Chief Security Architect of FrankPass and the FrankBase Ecosystem. Creator of the MMY_{constant} cryptographic protocol and stateless zero-knowledge password architecture.